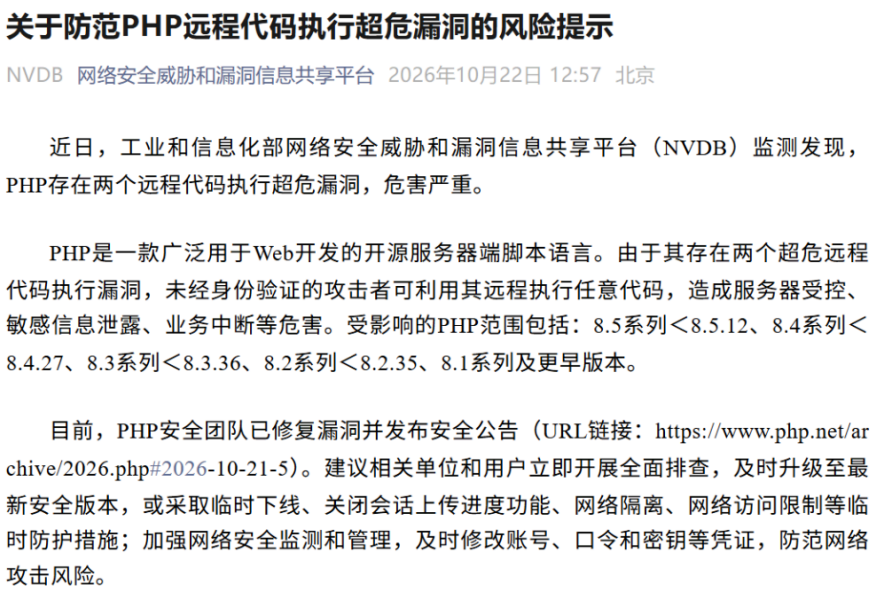
摘要：

该漏洞此前已在系统中潜伏超过十年。工信部在风险提示中明确列出应对优先级：相关单位和用户应立即开展全面排查，及时升级至PHP官方发布的最新安全版本。对于短期内无法完成升级的机构，官方建议采取临时下线、关闭会话上传进度功能、网络隔离或访问限制等临时防护措施，同时加强网络安全监测，及时更换账号、口令和密钥等凭证。

工业和信息化部网络安全威胁和漏洞信息共享平台（NVDB）发布紧急提示，PHP存在两个远程代码执行超危漏洞，攻击者无需任何身份验证即可直接入侵目标系统，建议相关单位和用户立即排查并升级至最新安全版本。



关于防范PHP远程代码执行超危漏洞的风险提示

NVDB 网络安全威胁和漏洞信息共享平台 2026年10月22日 12:57 北京

近日，工业和信息化部网络安全威胁和漏洞信息共享平台（NVDB）监测发现，PHP存在两个远程代码执行超危漏洞，危害严重。

PHP是一款广泛用于Web开发的开源服务器端脚本语言。由于其存在两个超危远程代码执行漏洞，未经身份验证的攻击者可利用其远程执行任意代码，造成服务器受控、敏感信息泄露、业务中断等危害。受影响的PHP范围包括：8.5系列＜8.5.12、8.4系列＜8.4.27、8.3系列＜8.3.36、8.2系列＜8.2.35、8.1系列及更早版本。

目前，PHP安全团队已修复漏洞并发布安全公告（URL链接：https://www.php.net/archive/2026.php#2026-10-21-5）。建议相关单位和用户立即开展全面排查，及时升级至最新安全版本，或采取临时下线、关闭会话上传进度功能、网络隔离、网络访问限制等临时防护措施；加强网络安全监测和管理，及时修改账号、口令和密钥等凭证，防范网络攻击风险。

此次漏洞波及范围极广，全球约七成网站底层依赖PHP运行，从政府服务到金融机构均面临直接安全威胁。网络安全公司Cloudflare披露，漏洞曝光后已检测到数百万次利用尝试；亚马逊则表示，黑客早在漏洞公开四天前便已着手尝试利用该缺陷。

在应对层面，芬兰、法国、荷兰等国率先将部分政府服务主动下线；日本多家航空、金融、消费品及游戏企业相继宣布服务中断；阿里云、腾讯云亦于事件曝光后发出紧急警告，要求客户尽快完成版本升级。

无需登录即可入侵，漏洞危害严重

此次被曝光的两个漏洞，**核心风险在于攻击门槛极低。未经身份验证的攻击者可直接对运行PHP的服务器发动攻击，远程执行任意代码，进而导致服务器受控、敏感信息泄露及业务中断。**

受影响的PHP版本范围广泛，包括：8.5系列低于8.5.12、8.4系列低于8.4.27、8.3系列低于8.3.36、8.2系列低于8.2.35，以及8.1系列及更早版本。

漏洞由美国两家网络安全机构Calif和Wiz的研究人员发现，借助OpenAI和谷歌的AI模型辅助分析后方才识别。**值得关注的是，该漏洞此前已在系统中潜伏超过十年。**

工信部在风险提示中明确列出应对优先级：**相关单位和用户应立即开展全面排查，及时升级至PHP官方发布的最新安全版本。**

对于短期内无法完成升级的机构，**官方建议采取临时下线、关闭会话上传进度功能、网络隔离或访问限制等临时防护措施，同时加强网络安全监测，及时更换账号、口令和密钥等凭证。**

多国选择主动下线，以时间换安全

PHP作为全球最广泛使用的服务器端脚本语言之一，为互联网基础设施提供底层支撑。网络安全公司Wiz估计，**受影响的PHP语言驱动了全球约70%的网站，其中包括建站平台WordPress。**

这一规模意味着，从个人博客、中小企业官网到政府公共服务平台，均潜在处于攻击者的打击范围之内。美国国家安全局（NSA）及欧洲网络安全机构相继就此发出警告，要求企业立即采取行动。

面对漏洞曝光后攻击尝试的急速攀升，多国政府和企业选择主动关停相关服务。

在欧洲，芬兰、法国、荷兰率先对部分政府服务采取预防性下线。澳大利亚信号局于周三深夜发布警告，敦促企业及用户尽快更新补丁，但仍有部分政府网站因此陷入无法访问状态。在亚太地区，韩国将私营部门网络危机预警级别上调，并召集国防部、科学与信息通信技术部及国家情报院官员举行紧急会议。

日本方面，航空公司全日空（ANA）宣布暂停网站及应用程序服务，包括Apple Wallet登机牌功能；野村证券旗下子公司及三菱UFJ金融集团（MUFG）暂停部分非核心服务，三菱UFJ表示停摆不影响支付业务；日本最大啤酒商朝日集团、铁路运营商京阪控股、游戏企业世嘉（Sega）和万代南梦宫（Bandai Namco）亦相继宣布对相关网站进行紧急维护或暂停部分功能。

中小企业和普通用户同样承压

尽管此次漏洞引发广泛关注，部分专业人士提示，不同类型机构面临的实际风险存在显著差异。

莫纳什大学学者Rashina Hoda表示，大型银行和企业通常不依赖PHP处理敏感交易，因此受到的直接冲击相对有限。然而，大量高度依赖WordPress等建站平台的中小型企业，其网站底层正是PHP，这类企业将面临更为迫切的修复压力。

Hoda同时警告，此次漏洞曝光可能引发网络诈骗和网络钓鱼攻击的激增。攻击者往往借助重大安全事件制造恐慌，诱导用户点击虚假"补丁链接"或提交账户信息。

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时权益申领
* 体验资格每人限申领一次
VIP会员·7天畅读卡 | 大师课·入门串讲
扫码
免费领取



限免

50 收藏

分享到:

写评论

请发表您的评论

表情 图片

发布评论